



# Requirement 3: Protect Stored Account Data

---

IMPLEMENT ROBUST SAFEGUARDS TO SECURE SENSITIVE ACCOUNT  
INFORMATION AT REST







# The Importance of Protecting Stored Account Data

## Breaches impact reputation, trust, and psychological safety

- Legal, financial, and social consequences arise from breaches

## Failure leads to legal and financial penalties

- Restoring confidence is difficult after a breach

## Protecting account data is a cornerstone of integrity

- Security goes beyond technical compliance alone

## Robust protection ensures organizational resilience

- Resilience depends on proactive and ongoing safeguards

# Fundamentals of Account Data Protection

**Sensitive info must not be exposed to unauthorized access**

- Applies to PANs in all storage locations

**Compliance is not the sole objective**

- Emphasizes a culture of proactive defense

**Minimize stored data to reduce exposure risk**

- Only essential data should be retained

**Cryptographic keys require equal vigilance**

- Manage keys as carefully as account data itself





# Data Minimization: Reducing Risk Through Retention Review

---

## Retain only information necessary for business functions

- Evaluate need for each data element regularly

## Limiting data reduces attack surface and compromise scope

- Less data means lower risk if breached

## Indefinite retention increases vulnerability

- Avoid storing data longer than required

## “Less is more” shapes secure data retention culture

- Assess legacy systems and backups for excess data



# Making Account Data Unreadable: Tokenization and Encryption

Tokenization and encryption guard data from unauthorized parties

- Both render compromised data meaningless to attackers

Encryption uses algorithms and cryptographic keys

- Only authorized access can decrypt sensitive information

Tokenization replaces data with non-sensitive tokens

- Tokens are useless without the token-mapping system

Choice depends on business and technical requirements

- Evaluate use cases and risk factors before selecting a method





# Encryption vs. Tokenization: Practical Differences

## Encryption locks data using cryptographic keys

- Only key holders can unlock and access data

## Tokenization substitutes data with non-sensitive copies

- Tokens reference originals stored separately and securely

## Tokenization supports business processes without risk exposure

- Tokens retain utility for refunds or recurring payments

## Encryption is suitable if original data must be accessed

- Useful when operations require actual account numbers



# Prohibiting Storage of Sensitive Authentication Data (SAD)

SAD includes full magnetic stripe data, CVCs, and PINs

- SAD is never to be stored after authorization

Retaining SAD increases fraud and compliance risk

- Prohibition prevents unauthorized use after transactions

SAD in call recordings or logs is non-compliant

- Breaches often stem from overlooked SAD in archives

All storage types must be monitored for SAD

- Include files, audio, logs, and screenshots in reviews



# Cryptographic Key Management Lifecycle

---

Key management includes generation, distribution, storage, use

- Each phase has unique security challenges and opportunities

Weak key generation increases vulnerability

- Low entropy makes keys easier to crack

Keys must not be stored with encrypted data

- Avoid storing keys and data in the same location

Restrict and audit all key access and use

- Log every use for accountability and audits





# Key Management: Rotation, Revocation, Destruction

## Regular key rotation limits attacker opportunity

- Compromised keys expose less data after rotation

## Missing rotation controls increase organizational risk

- Omitted processes leave data persistently vulnerable

## Review policies for all lifecycle controls regularly

- Detect and address gaps in revocation or destruction steps

## Mature key management improves risk and compliance posture

- Strong controls reflect advanced security maturity





# Lessons from Industry: Interdependent Controls

## Encryption fails if keys are stored with encrypted data

- Breaches occur when both are accessible to attackers

## Controls must operate in concert for real protection

- Data minimization, unreadable rendering, and key management are linked

## Neglecting any protection area undermines security

- All controls are interdependent and essential

## Reputation and compliance depend on holistic implementation

- Fines and confidence loss follow inadequate controls



# Reflection: Applying Principles and Practice

## Select between tokenization and encryption based on use and risk

- Choose according to operational needs and threat level

## Assess datastore protection and articulate rationale

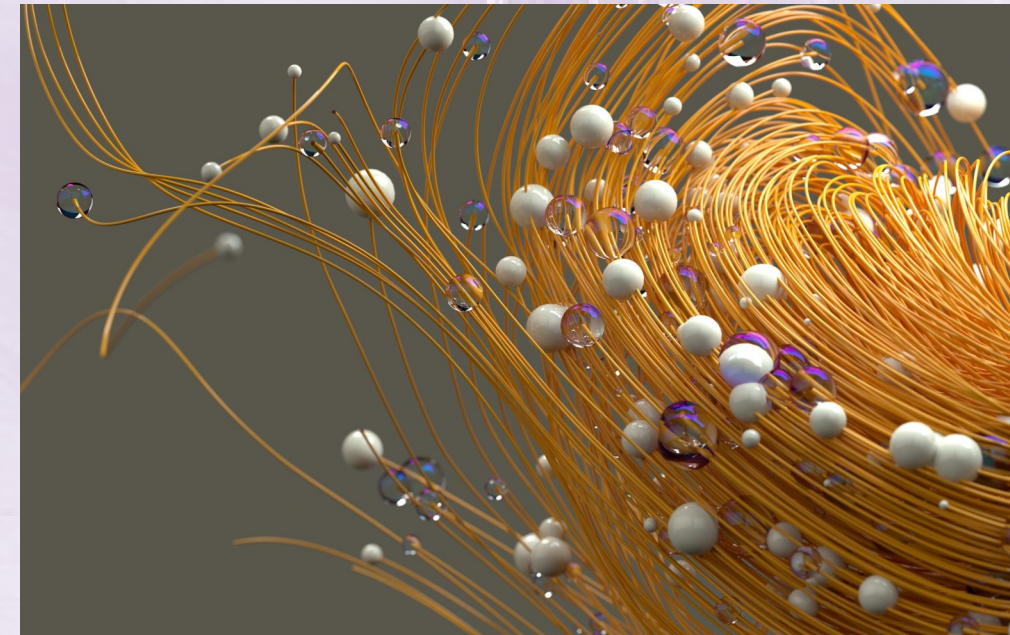
- Explain choices with reference to risk and business factors

## Review all controls in the key management document

- Identify missing or insufficient lifecycle steps

## Reflection turns knowledge into actionable skill

- Use self-assessment to foster professional growth



# Summary: The Responsibilities of Protecting Account Data

---

## Data minimization reduces risk and attack surface

- Retain only necessary information for business operations

## Unreadable rendering shields against unauthorized access

- Employ tokenization or encryption for strong protection

## Prohibit SAD storage after authorization for compliance

- SAD retention raises fraud and liability risk

## Key management must be holistic and rigorous

- Security strength mirrors quality of key controls





# Professionalism in Account Data Protection

## Mastery enables stewardship of compliance and trust

- True professionals safeguard data through discernment

## Apply protections to address evolving threats and needs

- Navigate changing landscapes with resilience and skill

## Excellence builds organizational and customer confidence

- Effective protection upholds public and partner trust

## Commitment to protection has lasting organizational impact

- Your diligence supports security and business values

